

Plan de Respuesta a Incidentes de Ransomware – TechCo

Informe alineado al Marco de Ciberseguridad NIST
Fecha: 19/05/2026

Este documento presenta un plan integral de respuesta a incidentes de ransomware para la empresa ficticia TechCo, tomando como referencia las funciones clave del Marco de Ciberseguridad NIST: Identificar, Proteger, Detectar, Responder y Recuperar.

1. Resumen Ejecutivo

TechCo sufrió un ataque de ransomware originado por un correo electrónico de phishing que permitió la ejecución de un archivo malicioso dentro de la red corporativa. La falta de segmentación de red, monitoreo en tiempo real y protección adecuada de respaldos permitió la propagación del malware hacia sistemas críticos, incluyendo servidores de archivos, bases de datos de clientes y sistemas de respaldo.

El objetivo de este plan es establecer controles preventivos, capacidades de detección temprana, procedimientos de respuesta y estrategias de recuperación que permitan reducir el impacto de futuros incidentes y fortalecer la postura de seguridad de TechCo.

2. Identificación (Identify)

2.1 Activos Críticos Afectados

Activo	Impacto
Servidor de Archivos	Almacenamiento de documentos operativos y archivos internos.
Base de Datos de Clientes	Información personal y financiera sensible.
Sistemas de Backup	Respaldos internos comprometidos por falta de segmentación.
Infraestructura de Red	Switches, firewalls y servicios de conectividad.
Cuentas de Usuario y Credenciales	Posible compromiso de accesos privilegiados.
Servicios en la Nube	Servicios críticos utilizados para operaciones diarias.

2.2 Vulnerabilidades Identificadas

- Falta de capacitación en phishing y concientización de usuarios.
- Ausencia de segmentación de red.
- Backups conectados a la misma red comprometida.

- Carencia de monitoreo en tiempo real y alertamiento temprano.
- Posible falta de políticas de hardening y control de privilegios.
- Ausencia de autenticación multifactor (MFA) en sistemas críticos.
- Falta de pruebas periódicas de recuperación ante desastres.

3. Protección (Protect)

TechCo debió implementar controles preventivos técnicos, administrativos y operativos para minimizar la posibilidad de compromiso y propagación del ransomware.

- Implementar campañas periódicas de concientización sobre el phishing.
- Habilitar autenticación multifactor (MFA) para accesos críticos.
- Aplicar segmentación de red entre producción, respaldos y usuarios.
- Implementar soluciones EDR/XDR en endpoints y servidores.
- Restringir privilegios administrativos bajo el principio de mínimo privilegio.
- Mantener políticas de parchado y actualización continua.
- Aplicar filtrado avanzado de correo electrónico y sandboxing de adjuntos.
- Configurar respaldos offline e inmutables.
- Deshabilitar macros y ejecución automática de archivos sospechosos.
- Implementar políticas de control de acceso basadas en roles.

4. Detección (Detect)

La detección temprana es fundamental para limitar el impacto de un ataque de ransomware.

4.1 Herramientas Recomendadas

Herramienta	Función
SIEM	Centralización de logs y correlación de eventos.
EDR/XDR	Detección de comportamiento malicioso en endpoints.
IDS/IPS	Detección y bloqueo de tráfico sospechoso.
Monitoreo de Integridad	Detección de cambios masivos en archivos.
Alertas de Anomalías	Identificación de cifrado masivo o conexiones inusuales.

4.2 Protocolo de Alerta Temprana

- Generar alertas automáticas por ejecución de archivos sospechosos.
- Detectar incrementos anormales de uso de CPU o actividad de cifrado.
- Monitorear intentos fallidos de autenticación y movimientos laterales.
- Configurar dashboards y notificaciones en tiempo real para el SOC.
- Definir umbrales de severidad y escalamiento inmediato.

5. Respuesta (Respond)

5.1 Procedimiento de Respuesta

1. Identificar y confirmar el incidente.
2. Aislar los sistemas afectados de la red.
3. Deshabilitar cuentas comprometidas.
4. Activar el equipo de respuesta a incidentes.
5. Preservar evidencias para análisis forense.
6. Evaluar el alcance del incidente.
7. Erradicar el malware y las vulnerabilidades asociadas.
8. Notificar a la dirección y áreas legales.
9. Realizar comunicación controlada hacia clientes y terceros.
10. Coordinar recuperación y validación de sistemas.

5.2 Roles y Responsabilidades

Rol	Responsabilidad
CISO / Responsable de Seguridad	Dirigir la respuesta y toma de decisiones.
SOC / Equipo de Monitoreo	Identificar y contener amenazas.
Infraestructura TI	Aislar sistemas y restaurar servicios.
Equipo Legal	Evaluar obligaciones regulatorias y contractuales.
Comunicación Corporativa	Gestionar mensajes internos y externos.
Alta Dirección	Autorizar acciones estratégicas y continuidad operativa.

5.3 Plan de Comunicación

- Informar inmediatamente a la dirección ejecutiva.
- Notificar al personal interno sobre medidas temporales.
- Mantener comunicación transparente con clientes afectados.
- Coordinar notificaciones regulatorias si aplica.
- Documentar todas las decisiones y acciones tomadas.

6. Recuperación (Recover)

- Restaurar servicios críticos utilizando respaldos seguros y verificados.
- Validar integridad de los sistemas antes de conectarlos a producción.
- Cambiar credenciales comprometidas.
- Aplicar parches y reforzar controles de seguridad.

- Realizar monitoreo intensivo posterior a la recuperación.
- Implementar ambientes alternos para continuidad operativa.
- Documentar tiempos de recuperación (RTO) y pérdida máxima aceptable (RPO).

6.1 Continuidad del Negocio

TechCo debe mantener un Plan de Continuidad de Negocio (BCP) y un Plan de Recuperación ante Desastres (DRP) que permitan mantener operaciones mínimas durante incidentes graves. Se recomienda contar con respaldos offline, sitios alternos y pruebas periódicas de recuperación.

7. Mejora Continua

- Realizar análisis post-incidente y sesiones de lecciones aprendidas.
- Actualizar políticas y procedimientos de seguridad.
- Ejecutar simulacros periódicos de ransomware.
- Medir indicadores clave como MTTR y tiempo de detección.
- Actualizar herramientas y controles de seguridad de forma continua.
- Capacitar regularmente al personal técnico y administrativo.

8. Conclusión

La implementación de un plan de respuesta alineado al marco NIST permitirá a TechCo mejorar significativamente su capacidad para prevenir, detectar, responder y recuperarse de ataques de ransomware. La combinación de controles técnicos, procesos claros, capacitación y mejora continua fortalecerá la resiliencia operativa y reducirá el impacto de futuros incidentes.